

Tableau de risques — Incident MIRAGE (AtlasGrid)

Pôle Risque / Conformité · Situation arrêtée J2 ~10:30 · Échelle : Probabilité (P) et Impact (I) de 1 à 4 ; Criticité = P × I (≥ 12 critique · 8–11 élevé · 4–7 moyen · ≤ 3 faible).
Références : loi 09-08 (données personnelles, CNDP), loi 05-20 (cybersécurité, DGSSI), loi 07-03 (atteintes aux STAD, code pénal).

Synthèse

Incident qualifié : rançongiciel avec double extorsion. Entrée par le compte VPN du prestataire OasisNet (sans MFA, 3 semaines, nuit, étranger) et hameçonnage (atlasgrid-it.info) ; patient zéro FIN-112 ; C2 actif ~10 j ; ~118 Go exfiltrés ; sauvegardes supprimées J1 03:15 ; 23 serveurs sur 40 chiffrés (paie, facturation, ERP, fichiers) ; AD dégradé ; OT/SCADA intact (air-gap). **Conséquence juridique** : il y a violation de données personnelles (confidentialité + disponibilité) et incident de sécurité notifiable. Une tentative de fraude au président (A-23, 480 000 MAD) exploite en parallèle la confusion.

1. Tableau de risques

#	Risque	Faits / preuves	Personnes & actifs exposés	P	I	Crit.	Cadre légal / contractuel	Traitement recommandé	Resp.
R1	Divulgarion des données personnelles exfiltrées (menace de mise aux enchères)	~118 Go sortis la nuit (A-03), C2 depuis FIN-112 ~10 j (A-09), note SIROCCO « données copiées »	Clients, salariés (paie/RH), fournisseurs	4	4	16	Loi 09-08 : obligation de sécurité du responsable de traitement (art. 23) ; CNDP	Qualifier la nature/volume des données ; informer la CNDP ; préparer l'info des personnes ; veille fuite (leak sites)	RSSI + DPO
R2	Arrêt des processus vitaux (paie, facturation, ERP)	23/40 serveurs CHIFFRÉ (A-13) : PAIE-01, FACT-02, ERP-APP/DB-01, FILER	Salariés (salaire du mois), clients, trésorerie	4	4	16	Code du travail (paiement des salaires) ; SLA 99,5 % Chérifienne des Mines	PCA : paie de secours (virement du mois N-1 reconduit), facturation manuelle ; priorités de restauration	Continuité + DAF
R3	Incident de sécurité non déclaré à l'autorité	Incident avéré et majeur depuis J2 matin	AtlasGrid (sanction, responsabilité des dirigeants)	3	4	12	Loi 05-20 + décret 2-21-406 : déclaration à la DGSSI dès connaissance ; renforcé si IIV (énergie/OT)	Déclarer aujourd'hui à la DGSSI / maCERT ; tracer l'heure de connaissance	Direction + RSSI
R4	Impossibilité de restaurer (sauvegardes détruites)	Suppression des backups J1 03:15 depuis FIN-112, AV désactivé (A-05)	Toutes les données métier	4	4	16	Loi 09-08 art. 23 (intégrité/disponibilité) ; obligations contractuelles OasisNet	Rechercher copies hors ligne/immuables ; ne pas « déchiffrer » avec l'outil attaquant sans avis forensic	Continuité
R5	Persistance de l'attaquant via le compte prestataire et l'AD	VPN OasisNet sans MFA (A-02), DC-01 authentification dégradée	SI entier, comptes à privilèges	4	3	12	Loi 09-08 art. 24 (sous-traitant) ; contrat d'infogérance	Désactiver le compte OasisNet ; reset des comptes privilégiés (krbtgt x2) ; MFA ; mise en demeure / demande de journaux au prestataire	SOC + Juridique
R6	Propagation vers l'OT / SCADA	SCADA-HMI intact, réseau isolé (A-13)	Supervision réseau, sécurité des personnes	1	4	4	Loi 05-20 (SI sensibles des IIV)	Maintenir l'air-gap ; interdire tout média/lien IT→OT ; surveillance renforcée	Continuité + OT
R7	Fraude au président / BEC	A-23 : 480 000 MAD, IBAN ES jamais utilisé, domaine sosie atlasgrid-finance.co	Trésorerie, comptables	3	3	9	Code pénal (escroquerie, loi 07-03) ; procédure de paiement interne	Ne pas payer ; alerte banque ; rappel « double validation + contre-appel » ; bloquer le domaine ; plainte	DAF + SOC
R8	Paiement de la rançon	Demande 20 BTC, délai 48 h, doublement annoncé	AtlasGrid, dirigeants	2	4	8	Aucune garantie ; risque de financement d'activité criminelle ; réglementation des changes (crypto)	Recommandation : ne pas payer ; ne pas négocier seul ; décision tracée de la Direction	Direction
R9	Perte ou altération des preuves	FIN-112 isolé sous tension (bon geste) ; horodatages suspects de la note (A-04)	Action pénale, assurance	2	3	6	Loi 07-03 (plainte) ; chaîne de custody	Images disque/RAM, hash, main courante horodatée ; plainte auprès de la police judiciaire (BNLCC)	Forensic
R10	Atteinte à la réputation et contentieux clients	Chérifienne des Mines exige explication écrite sous 24 h ; presse ; rumeurs internes	Image, clients grands comptes	4	3	12	Contrats clients (SLA, pénalités, force majeure à étudier)	Réponse écrite factuelle sous 24 h validée Juridique ; message interne avant ce soir	Communication
R11	Mise en cause injustifiée de salariés	Stagiaire (badge, FP-2), paie PAIE-SAUVE (FP-6), salarié qui a cliqué	Salariés concernés	2	2	4	Loi 09-08 (finalité, proportionnalité) ; code du travail	Confidentialité ; pas de sanction pour le signalement ; données d'enquête limitées au besoin	RH + DPO

Légende criticité : ■ critique ≥ 12 · ■ élevé 8-11 · ■ moyen 4-7 · ■ faible ≤ 3

2. Obligations de notification et échéances

Destinataire	Fondement	Déclencheur	Échéance	Contenu minimum	Statut / resp.
DGSSI / maCERT	Loi 05-20 et décret 2-21-406	Incident affectant la sécurité ou le fonctionnement du SI	Sans délai, dès connaissance → aujourd'hui (J2)	Nature, périmètre (23/40), vecteur (VPN prestataire), mesures prises	À faire · Direction + RSSI
CNDP	Loi 09-08 (sécurité des traitements, art. 23-24)	Exfiltration probable de données personnelles	Pas de délai légal chiffré : notifier au plus tôt ; cible interne ≤ 72 h (bonne pratique)	Catégories de données et de personnes, volume, risques, mesures	À faire · DPO
Personnes concernées	Loi 09-08 (loyauté, sécurité) ; recommandations CNDP	Risque élevé : données publiées ou identifiants exposés	Dès que les catégories exposées sont connues	Ce qui s'est passé, risques (phishing, fraude), gestes à faire, contact	À préparer · Com + DPO
Police judiciaire / parquet	Code pénal art. 607-3 s. (loi 07-03), extorsion	Intrusion STAD, rançon, tentative d'escroquerie A-23	Au plus tôt (préserve les preuves et l'assurance)	Plainte + main courante, IOC, preuves hachées	À faire · Juridique
Banque	Procédures bancaires anti-fraude	Ordre frauduleux A-23 (IBAN ES)	Immédiat	Signalement, blocage de tout paiement vers cet IBAN	À faire · DAF
Clients (Chérifienne des Mines...)	Contrat : SLA 99,5 %	Portail de facturation indisponible	Réponse écrite < 24 h	Faits établis, délai estimé, pas de spéculation sur les données	À faire · Com + Juridique
Assureur cyber (si police)	Contrat d'assurance	Sinistre cyber	Selon police (souvent 24-72 h)	Déclaration de sinistre, avant toute décision sur la rançon	À vérifier · DAF
Salariés / représentants	Dialogue social	Rumeurs, paie bloquée	Avant ce soir (J2)	Message court, factuel, consignes (vigilance BEC/phishing)	À faire · Com + RH

Note : les textes marocains ne fixent pas de délai chiffré pour notifier une violation à la CNDP (contrairement aux 72 h du RGPD, applicable si des résidents de l'UE sont concernés). La qualification d'AtlasGrid comme infrastructure d'importance vitale (loi 05-20) est à confirmer au regard de son activité réseau/OT ; si c'est le cas, les obligations DGSSI sont renforcées.

3. Pièce A-23 — Arnaque au président (BEC)

Verdict proposé : Fausse piste (pour l'enquête MIRAGE) — mais **risque réel traité en R7**. Justification : domaine sosie atlasgrid-finance.co ≠ atlasgrid.ma ; usurpation de la PDG ; urgence + confidentialité + « ne m'appellez pas » ; IBAN étranger jamais utilisé ; aucune pièce jointe, lien ni code malveillant → pas de lien technique avec le rançongiciel. C'est une fraude opportuniste qui exploite la crise. Aucun virement n'a été fait (bon réflexe du comptable). Point de vigilance : l'attaquant connaît le nom de la PDG et l'adresse du service fournisseurs, ce qui pourrait provenir des données exfiltrées — à vérifier.

4. Décisions demandées à la Direction (12:00)

- Valider la déclaration à la DGSSI aujourd'hui et la notification CNDP (échéance interne ≤ 72 h).
- Acter le non-paiement de la rançon et le dépôt de plainte.
- Suspendre le compte OasisNet, exiger ses journaux et une mise en demeure contractuelle.
- Imposer la double validation + contre-appel sur tout virement jusqu'à la fin de la crise.
- Autoriser la communication clients (< 24 h) et salariés (ce soir).